

MASTER PROMPT — Enterprise Security & Developer Features

You are a Senior Software Architect and Security Engineer.

Audit the entire project and implement **enterprise-grade security, performance, developer experience, and scalability** throughout the application. Apply these standards globally unless explicitly overridden.

Authentication & Identity

- * Email & Password Authentication
- * Google OAuth
- * GitHub OAuth
- * Microsoft OAuth
- * Apple Sign In (Future)
- * Passwordless Magic Links
- * Multi-Factor Authentication (TOTP)
- * Email OTP Verification
- * Device Session Management
- * Session Revocation
- * Secure Password Hashing (Argon2id/Bcrypt)
- * Password Strength Validation
- * Password Reset
- * Email Verification
- * Secure HttpOnly Cookies
- * SameSite Cookies
- * Secure Cookies

- * Session Timeout

- * Remember Me

- * Login History

Authorization

Implement Role-Based Access Control (RBAC)

Roles

- * Super Admin

- * Admin

- * Moderator

- * Developer

- * Member

- * Subscriber

- * Guest

Every API route must validate permissions server-side.

Never trust the frontend.

Database Security

- * Enable Row-Level Security (Supabase)
- * Parameterized Queries
- * Prevent SQL Injection
- * Database Encryption
- * Automatic Backups
- * Point-in-Time Recovery
- * Audit Tables
- * Soft Deletes
- * Optimized Indexes
- * Foreign Key Constraints

API Security

- * JWT Verification
- * Secure API Keys
- * API Key Rotation
- * API Key Expiration
- * API Key Revocation
- * HMAC Request Signing
- * Timestamp Validation
- * Replay Attack Protection
- * Request Validation
- * API Versioning
- * Rate Limiting
- * Usage Analytics

HTTPS

Enforce HTTPS everywhere.

Enable

- * TLS 1.3
- * HSTS
- * Secure Cookies

Rate Limiting

Protect

- * Login
- * Registration
- * Password Reset
- * API
- * AI Chat
- * File Upload
- * Admin Actions

Validation

Validate every request using Zod.

Prevent

- * SQL Injection
- * XSS
- * Command Injection
- * Prototype Pollution
- * XML Injection
- * SSRF

File Upload Security

Validate

- * MIME Type
- * File Extension
- * Magic Bytes
- * Maximum File Size
- * Virus Scan
- * Malware Scan

Rename uploaded files.

Never expose original filenames.

Store securely.

Security Headers

Automatically configure

- * Content-Security-Policy
- * Strict-Transport-Security
- * X-Frame-Options
- * Referrer-Policy
- * Permissions-Policy
- * X-Content-Type-Options
- * Cross-Origin Policies

Cross-Site Protection

Implement

- * CSRF Protection
- * XSS Protection
- * Clickjacking Protection
- * CSP

- * DOM Sanitization

Logging

Log

- * Login

- * Logout

- * Password Changes

- * Role Changes

- * Payments

- * Subscription Changes

- * AI Requests

- * File Uploads

- * API Usage

- * Admin Actions

- * Knowledge Base Updates

Include

- * User

- * Time

- * Browser

- * IP

- * Country

- * Device

Audit Trail

Maintain immutable audit logs.

Never permanently delete critical records.

Archive instead.

Encryption

Encrypt

- * API Keys

- * Tokens

- * Secrets

- * Sensitive Settings

- * Payment References

Never expose secrets to the client.

Environment Variables

Secure

- * OpenAI Keys
- * Supabase Keys
- * SMTP Credentials
- * Payment Keys
- * OAuth Secrets

Never expose server secrets to frontend bundles.

AI Security

Implement

- * Prompt Injection Detection
- * Jailbreak Detection
- * Prompt Sanitization
- * Prompt Versioning
- * Prompt Logging
- * Context Validation
- * Token Usage Tracking
- * Cost Tracking
- * AI Rate Limiting
- * AI Conversation Moderation
- * Sensitive Data Detection

Prevent the AI from exposing

- * System Prompts
- * API Keys
- * Internal Documents
- * Hidden Instructions
- * Private User Data

Knowledge Base Security

Restrict upload/edit/delete/publish to Admins only.

Protect

- * Embeddings
- * Vector Database
- * Internal Documents
- * Processing Pipelines

Payment Security

Track

- * Payment Reference
- * Uploaded Proof
- * Verification History
- * Admin Approval
- * Audit Logs

Notification Security

Support

- * Email
- * SMS (Future)
- * WhatsApp (Future)
- * Push Notifications (Future)

Verify delivery status.

Monitoring

Integrate

- * Sentry
- * Better Stack
- * PostHog

Track

- * Errors
- * Performance
- * Slow Queries
- * Crashes
- * AI Failures
- * Background Job Failures

Background Jobs

Create queue workers for

- * AI Embeddings
- * OCR
- * Video Processing
- * Audio Transcription
- * Email Sending
- * Notifications
- * Scheduled Tasks
- * Backups

Support retries and dead-letter queues.

Backup Strategy

Automatic

- * Daily

- * Weekly

- * Monthly

Encrypted backups.

Support restore testing.

DDoS Protection

Support

- * Cloudflare

- * Vercel Firewall

- * IP Blocking

- * Request Throttling

Bot Protection

Protect

- * Login
- * Registration
- * Contact Forms
- * Password Reset

Use

- * Cloudflare Turnstile
- * reCAPTCHA (optional)

Admin Dashboard Security

Require

- * MFA
- * RBAC
- * Audit Logs

Support

- * IP Allowlisting (optional)
- * Session Monitoring

Developer Portal

Implement

- * API Documentation
- * OpenAPI/Swagger
- * SDK Downloads
- * API Playground
- * Webhook Testing
- * API Analytics
- * Usage Dashboard
- * Error Logs

Feature Flags

Create a Feature Flag System.

Support

- * Enable/Disable Features
- * Beta Features
- * A/B Testing
- * Gradual Rollouts
- * Environment-Based Flags

Notification Center

Support

- * In-App Notifications
- * Email Notifications
- * System Alerts
- * Subscription Alerts
- * AI Usage Alerts

Analytics

Track

- * Active Users
- * Daily Users
- * Monthly Users
- * AI Conversations
- * AI Cost
- * AI Tokens
- * Subscription Revenue
- * API Usage
- * Knowledge Searches
- * Most Asked Questions

- * Popular Articles

Search

Implement

- * Global Search

- * Semantic Search

- * Full-Text Search

- * Hybrid Search

Across

- * Users

- * Knowledge Base

- * Files

- * Payments

- * API Logs

Storage

Support

- * Documents

- * Images

- * Audio

- * Videos

- * PDFs

Include

- * Versioning

- * Soft Delete

- * Secure URLs

- * Signed URLs

AI Knowledge

Support ingestion from

- * Articles

- * FAQs

- * PDFs

- * DOCX

- * TXT

- * Markdown

- * CSV

- * XLSX

- * PPTX

- * Images (OCR)

- * Audio (Speech-to-Text)
- * Videos (Transcription)
- * Websites
- * RSS
- * Notion (Future)
- * Google Drive (Future)
- * OneDrive (Future)
- * Dropbox (Future)
- * SharePoint (Future)
- * GitHub Wiki (Future)

Automatically

- * Extract Content
- * Chunk Text
- * Generate Embeddings
- * Store in Vector Database
- * Re-index on Update

API Platform

Implement

- * API Keys
- * API Dashboard
- * Usage Limits

- * Usage Charts
- * Webhooks
- * API Logs
- * API Documentation
- * API Playground
- * API Analytics

Subscription System

Support

- * Weekly
- * Monthly
- * Yearly

Status

- * Pending
- * Active
- * Expired
- * Suspended
- * Cancelled

Support future payment providers

- * Manual Transfer

- * Paystack
- * Flutterwave
- * Stripe

Performance

Optimize

- * Lazy Loading
- * Code Splitting
- * Image Optimization
- * Query Optimization
- * CDN Support
- * Edge Functions
- * Redis Caching (Future)
- * Response Compression
- * Streaming Responses

Error Handling

Create

- * Global Error Boundary
- * API Error Handler

- * Retry Logic
- * User-Friendly Error Pages
- * Automatic Error Logging

Testing

Implement

- * Unit Tests
- * Integration Tests
- * End-to-End Tests
- * API Tests
- * Security Tests

CI/CD

Configure

- * Automated Builds
- * Linting
- * Type Checking
- * Dependency Scanning
- * Security Scanning
- * Automatic Deployments

- * Rollback Support

Mobile & PWA

Support

- * PWA
- * Offline Mode
- * Push Notifications
- * Secure Local Storage
- * Biometric Authentication (Future)
- * Certificate Pinning (Mobile)

Accessibility

Ensure WCAG 2.2 AA compliance.

Implement

- * Keyboard Navigation
- * Screen Reader Support
- * Proper ARIA Labels
- * High Contrast Support
- * Reduced Motion Support

Code Quality

Maintain

- * Modular Architecture
- * Clean Folder Structure
- * Reusable Components
- * Reusable Hooks
- * Shared UI Library
- * Type Safety
- * Consistent Naming
- * Comprehensive Documentation
- * Scalable Service Layer
- * SOLID Principles
- * DRY Principles
- * Dependency Injection where appropriate

Goal

The final application should be secure, scalable, maintainable, enterprise-ready, cloud-native, AI-ready, API-ready, mobile-ready, and future-proof. Every feature should follow modern software engineering best practices, emphasizing security by default, performance optimization, clean architecture, extensibility, and an exceptional developer experience.